

CLOUD SEC & IA

CLOUD INFRASTRUCTURE SECURITY



4

LISTA DE FIGURAS

Figura 1 - Ícone do AWS Key Management Service (KMS)	7
Figura 2 - Ícone do AWS WAF (Web Application Firewall).....	14
Figura 3 - Ícone do AWS Shield	16
Figura 4 - Ícone do AWS Security Hub.....	18
Figura 5 - Ícone do Amazon Virtual Private Cloud (VPC)	20
Figura 6 - Acesso a console de gerenciamento da AWS	23
Figura 7 - Acessando serviços KMS	23
Figura 8 - Acessar Chaves gerenciadas pelo cliente	23
Figura 9 - Iniciar criação de chave gerenciada pelo cliente.....	23
Figura 10 - Etapa 1 - Configurar Chave	24
Figura 11 - Etapa 2 - Configurar rótulos	24
Figura 12 - Etapa 3 - Definir permissões administrativas da chave.....	25
Figura 13 - Etapa 4 - Definir permissões de uso da chave.....	25
Figura 14 - Etapa 5 - Revisar	26
Figura 15 - Chave KMS criada	26
Figura 16 - Console de gerenciamento da AWS	26
Figura 17 - Acessando o serviço S3.....	27
Figura 18 - Criando Bucket no Amazon S3 parte 1	27
Figura 19 - Criando Bucket no Amazon S3 parte 2	27
Figura 20 - Criação de Bucket - Passagem de Parâmetros - Parte 1.....	28
Figura 21 - Criação de Bucket - Passagem de Parâmetros - Parte 2.....	28
Figura 22 - Finalização da criação do bucket criptografado	28
Figura 23 - Validação da criação do Bucket.....	29
Figura 24 - Propriedades do Bucket.....	29
Figura 25 - Validação do bucket criptografado com a chave.....	29
Figura 26 - Console de gerenciamento da AWS	30
Figura 27 - Acessando serviço WAF	30
Figura 28 - Acessando Web ACLs	31
Figura 29 - Criando Web ACL no WAF & Shield	31
Figura 30 - Etapa 1 - Criação Web ACL - Parte 1	32
Figura 31 - Etapa 1 - Criação Web ACL - Parte 2	32
Figura 32 - Etapa 1 - Adicionar Regras - Parte 3	32
Figura 33 - Ativar Core rule set	32
Figura 34 - Adicionar regras	33
Figura 35 - Etapa 2 - Conclusão.....	33
Figura 36 - Etapa 3 - Conclusão.....	33
Figura 37 - Etapa 4 - Conclusão.....	33
Figura 38 - Etapa 5 - Conclusão.....	34
Figura 39 - Validação da criação da Web ACL.....	34
Figura 40 - Página inicial do console.....	34
Figura 41 - Acessando o serviço CloudFront	35
Figura 42 - Acessando Distribuições do CloudFront	35
Figura 43 - Iniciando a criação de Distribuições.....	35
Figura 44 - Criação de Distribuição no CloudFront - Parte 1.....	35
Figura 45 - Criação de Distribuição no CloudFront - Parte 2.....	36
Figura 46 - Criação de Distribuição no CloudFront - Parte 3.....	36
Figura 47 - Confirmação da criação da distribuição CloudFront.....	37

SUMÁRIO

SEGURANÇA DE INFRAESTRUTURA	4
1 INTRODUÇÃO À SEGURANÇA DE INFRAESTRUTURA.....	4
2 SERVIÇOS.....	5
2.1 AWS Key Management Service (KMS)	5
2.1.1 Criptografia do lado do cliente	9
2.1.2 Criptografia do lado do servidor	9
3 DIFERENÇAS ENTRE SSE-S3, SSE-KMS E SSE-C	10
3.1 SSE-S3 (Server-Side Encryption with Amazon S3):.....	10
3.2 SSE-KMS (Server-Side Encryption with AWS Key Management Service):.....	10
3.3 SSE-C (Server-Side Encryption with Customer-Provided Keys):	11
4 AWS WAF (WEB APPLICATION FIREWALL)	11
4.1 WebACL	13
5 AWS SHIELD	14
6 AWS SECURITY HUB	16
7 AMAZON VPC (VIRTUAL PRIVATE CLOUD)	18
8 EXEMPLOS PRÁTICOS (HANDS-ON).....	22
8.1 Criptografia de dados com AWS Key Management Service (KMS)	22
8.2 Proteção de aplicação com AWS WAF (Web Application Firewall).....	30
9 DESAFIOS	37
9.1 Controle de autenticação de usuários com AWS Identity and Access Management (IAM).....	38
9.2 Rastreamento de alterações de infraestrutura com AWS CloudTrail	40
9.3 Gestão de configuração de infraestrutura com AWS Config	42
9.4 Análise de eventos com GuardDuty	43
9.5 Proteção a ataques DDoS Shield	45
9.6 Provisionamento seguro de VPC	47
9.7 Coleta e análise de dados com Security Hub.....	49
REFERÊNCIAS.....	52

SEGURANÇA DE INFRAESTRUTURA

1 INTRODUÇÃO À SEGURANÇA DE INFRAESTRUTURA

O domínio de segurança de infraestrutura é um componente essencial da segurança da computação em nuvem. Ele abrange as práticas, os processos e as tecnologias que são projetadas para proteger a infraestrutura física e virtual utilizada para executar e suportar serviços na nuvem. A justificativa e a relevância desse domínio estão relacionadas à necessidade de garantir a confidencialidade, integridade e disponibilidade dos recursos e dados armazenados e processados na nuvem.

A segurança da infraestrutura é crucial porque, na computação em nuvem, os recursos físicos, como servidores, armazenamento e redes, são compartilhados entre várias organizações e usuários. Isso significa que a proteção adequada desses recursos é fundamental para evitar violações de segurança e garantir que os serviços e os dados confiados aos provedores de nuvem estejam protegidos contra ameaças internas e externas.

O domínio 3 abrange várias áreas-chave da segurança da infraestrutura, incluindo:

1. **Segurança física:** Envolve a proteção dos data centers e dos recursos físicos contra acesso não autorizado, roubo, incêndios, desastres naturais e outros eventos que possam comprometer a disponibilidade dos serviços.

2. **Segurança de rede:** Garante a proteção das redes utilizadas para comunicação entre os recursos da nuvem, bem como a segregação adequada entre redes de diferentes clientes ou ambientes.

3. **Gerenciamento de identidade e acesso:** Aborda a autenticação, autorização e gestão de direitos de acesso aos recursos da infraestrutura, com o objetivo de garantir que apenas usuários autorizados tenham permissão para acessar, modificar ou excluir recursos.

4. **Segurança de dados:** Envolve a proteção dos dados em repouso e em trânsito, incluindo criptografia, controle de acesso, monitoramento de integridade e medidas para evitar vazamentos ou acesso não autorizado aos dados.

5. Monitoramento e detecção de ameaças: Inclui a implementação de ferramentas e técnicas de monitoramento de segurança para detectar atividades suspeitas ou maliciosas, bem como a resposta efetiva a incidentes de segurança.

A segurança da infraestrutura é fundamental para garantir a confiança e a proteção dos serviços em nuvem. Os provedores de nuvem, como a AWS, têm a responsabilidade de implementar medidas de segurança robustas em suas infraestruturas para proteger os dados e os recursos de seus clientes. Os profissionais de segurança devem ter conhecimentos sólidos neste domínio para garantir a implementação adequada de controles de segurança e práticas recomendadas na infraestrutura da nuvem, a fim de mitigar riscos e proteger contra ameaças emergentes.

2 SERVIÇOS

A AWS oferece uma ampla gama de serviços que podem ser utilizados para tratar o domínio 3 - segurança de infraestrutura de forma detalhada. Abaixo estão alguns dos principais serviços da AWS que podem ser empregados nesse contexto, juntamente com seus casos de uso típicos:

2.1 AWS Key Management Service (KMS)

- **Descrição:** O AWS Key Management Service (KMS) é um serviço gerenciado de criptografia de chaves que permite criar, controlar e gerenciar chaves de criptografia para proteger dados confidenciais armazenados e transmitidos em serviços da AWS. Ele desempenha um papel essencial no domínio de Segurança de Infraestrutura, fornecendo recursos de criptografia robustos e centralizados para proteger dados sensíveis em ambientes de nuvem. O AWS KMS oferece várias funcionalidades-chave para a segurança da infraestrutura:
 - 1) Gerenciamento de chaves: O KMS permite criar e gerenciar hierarquias de chaves de criptografia mestra (CMKs), que são usadas para criptografar e descriptografar dados. Ele oferece controle granular sobre o gerenciamento de chaves, incluindo a capacidade de criar, rotacionar,

desativar e excluir chaves, bem como definir políticas de acesso para restringir o uso das chaves.

- 2) Criptografia de dados: Com o AWS KMS, você pode criptografar dados armazenados em serviços da AWS, como o Amazon S3, o Amazon EBS e o Amazon RDS. Ele também oferece recursos de criptografia de dados em trânsito, permitindo a criptografia de comunicações entre serviços, como a criptografia de dados em uma transferência de dados entre o Amazon S3 e o Amazon EC2.
- 3) Integração com outros serviços: O KMS é integrado a vários serviços da AWS, o que facilita a implementação de criptografia de ponta a ponta em toda a infraestrutura. Por exemplo, ele pode ser usado em conjunto com o AWS CloudTrail para criptografar registros de atividades, o AWS Lambda para criptografar dados em trânsito e o AWS EBS para criptografar volumes de armazenamento.
- 4) Controle de acesso e auditoria: O KMS oferece recursos avançados de controle de acesso, permitindo definir políticas granulares para conceder permissões de uso das chaves. Isso garante que apenas usuários autorizados possam criptografar e descriptografar dados protegidos pelas chaves. Além disso, o KMS registra todas as operações realizadas nas chaves em logs de auditoria para fins de conformidade e rastreamento. Ao utilizar o AWS KMS, as organizações podem atender a requisitos de segurança e conformidade, garantindo que os dados sensíveis estejam protegidos por criptografia. Além disso, o KMS simplifica o gerenciamento de chaves e reduz a carga operacional, uma vez que as chaves são gerenciadas e protegidas de forma centralizada pelo serviço.

- **Caso de uso:** Use o KMS para criptografar dados sensíveis armazenados em serviços da AWS, como o Amazon S3 ou o Amazon RDS. Ele permite gerenciar o ciclo de vida das chaves de criptografia e controlar o acesso a esses dados (GOLDFARB et al., 2021).

A figura “Ícone do AWS Key Management Service (KMS)” representa o ícone padrão da própria AWS para este serviço.

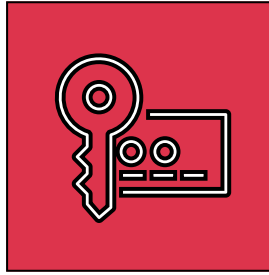


Figura 1 - Ícone do AWS Key Management Service (KMS)
Fonte: AWS (2023)

Assim sendo, o AWS Key Management Service (KMS) é um serviço essencial para a segurança de infraestrutura na AWS. Ele fornece recursos avançados de criptografia e gerenciamento de chaves, permitindo a proteção de dados confidenciais armazenados e transmitidos em serviços da AWS. Ao utilizar o KMS, as organizações podem garantir a confidencialidade e a integridade dos dados, bem como cumprir requisitos regulatórios relacionados à segurança da informação (GOLDFARB et al., 2021).

O AWS Key Management Service (KMS) é um serviço de gerenciamento de chaves que permite criar, importar, armazenar e gerenciar chaves de criptografia na AWS. O KMS oferece suporte a diferentes tipos de chaves, cada uma com uma finalidade específica. A seguir, estão os principais tipos de chaves suportados pelo AWS KMS:

- 1 Chaves simétricas (AES-256): O AWS KMS oferece a capacidade de gerar chaves simétricas criptograficamente fortes usando o algoritmo Advanced Encryption Standard (AES) com um tamanho de chave de 256 bits. Essas chaves são usadas para criptografar e descriptografar dados de forma eficiente. Um exemplo de uso é a criptografia de arquivos em repouso, como backups ou arquivos armazenados em serviços da AWS (GOLDFARB et al., 2021).
- 2 Chaves assimétricas (RSA e ECC): O KMS também suporta chaves assimétricas, incluindo o algoritmo de criptografia RSA (Rivest-Shamir-Adleman) e o algoritmo de curva elíptica (Elliptic Curve Cryptography - ECC). Essas chaves são usadas principalmente para operações de assinatura digital e criptografia assimétrica. Por exemplo, você pode usar chaves assimétricas para assinar tokens de autenticação, certificados digitais ou trocar chaves de sessão seguras (GOLDFARB et al., 2021).

- 3 Chaves mestras de envelope (envelope encryption): O KMS permite a criação de chaves mestras de envelope que são usadas para proteger chaves de dados específicas. Essas chaves são usadas na técnica de criptografia conhecida como envelope encryption, onde uma chave mestra é usada para criptografar e descriptografar chaves de dados que são usadas para criptografar o conteúdo real. Isso ajuda a proteger os dados, uma vez que as chaves de dados são armazenadas de forma segura e gerenciadas pelo KMS (GOLDFARB et al., 2021).
- 4 Chaves de recursos: O AWS KMS também suporta chaves de recursos que são usadas para criptografar e descriptografar dados específicos de recursos da AWS. Por exemplo, o Amazon S3 pode usar chaves de recursos gerenciadas pelo KMS para criptografar os dados armazenados em um bucket. Essas chaves são associadas a recursos específicos e oferecem um controle granular sobre a criptografia e acesso aos dados (GOLDFARB et al., 2021).

É importante mencionar que o AWS KMS não armazena os dados criptografados, mas sim as chaves de criptografia usadas para proteger os dados. As chaves são gerenciadas de forma segura pelo KMS, seguindo práticas recomendadas de segurança. Além disso, o KMS oferece recursos avançados, como rotação automática de chaves e auditoria de acesso às chaves (GOLDFARB et al., 2021).

Em resumo, o AWS Key Management Service (KMS) suporta diferentes tipos de chaves, incluindo chaves simétricas, assimétricas, mestras de envelope e chaves de recursos. Cada tipo de chave tem uma finalidade específica e pode ser usado para proteger dados e recursos na AWS. O KMS oferece recursos avançados de gerenciamento de chaves e ajuda a garantir a segurança e a conformidade dos dados criptografados na nuvem (GOLDFARB et al., 2021).

O AWS Key Management Service (KMS) suporta diversos tipos de criptografia tanto do lado do cliente quanto do lado do servidor. A seguir, estão os principais tipos de criptografia suportados pelo AWS KMS:

2.1.1 Criptografia do lado do cliente

- 1 Criptografia de dados: O KMS permite criptografar e descriptografar dados do cliente usando chaves simétricas (AES-256). O cliente pode solicitar ao KMS a geração de uma chave de dados ou pode importar uma chave existente. Com a chave criada ou importada, o cliente pode realizar operações de criptografia e descriptografia para proteger dados sensíveis antes de armazená-los ou transmiti-los (GOLDFARB et al., 2021).
- 2 Envelope Encryption: O KMS oferece suporte à técnica de Envelope Encryption, onde uma chave mestra é usada para criptografar e descriptografar chaves de dados. Isso permite que o cliente proteja chaves de dados específicas usando uma chave mestra gerenciada pelo KMS. Por exemplo, o cliente pode solicitar ao KMS a criação de uma chave mestra de envelope para criptografar chaves de dados usadas para proteger dados sensíveis (GOLDFARB et al., 2021).

2.1.2 Criptografia do lado do servidor

- 1 Criptografia de recursos: O KMS suporta a criptografia de recursos específicos da AWS, como dados armazenados no Amazon S3, Amazon EBS, Amazon RDS e outros serviços. O cliente pode associar chaves gerenciadas pelo KMS a esses recursos para criptografar e descriptografar os dados armazenados neles. Por exemplo, o cliente pode usar o KMS para criar uma chave mestra para um bucket do Amazon S3 e criptografar todos os objetos armazenados nesse bucket (GOLDFARB et al., 2021).
- 2 Criptografia de dados em trânsito: O KMS suporta a criptografia de dados em trânsito entre serviços da AWS usando chaves gerenciadas pelo KMS. Por exemplo, ao copiar dados entre regiões da AWS ou ao replicar dados entre serviços, o KMS pode ser usado para criptografar os dados durante a transferência, garantindo a segurança e a integridade dos dados em trânsito (GOLDFARB et al., 2021).
- 3 Gerenciamento de chaves de serviços: O KMS também é responsável pelo gerenciamento de chaves de serviços específicos da AWS. Por exemplo, o

AWS CloudHSM, um módulo de segurança de hardware, usa o KMS para gerenciar as chaves criptográficas armazenadas no HSM. O KMS permite criar, importar e gerenciar chaves criptográficas para uso com o CloudHSM (GOLDFARB et al., 2021).

Em resumo, o AWS Key Management Service (KMS) suporta criptografia do lado do cliente e do lado do servidor. Ele oferece a capacidade de criptografar e descriptografar dados do cliente usando chaves simétricas, realizar a técnica de Envelope Encryption, criptografar recursos específicos da AWS e gerenciar chaves criptográficas para serviços específicos. Com o KMS, os clientes podem garantir a segurança e a confidencialidade dos dados em repouso e em trânsito, bem como gerenciar o acesso e a proteção de recursos na nuvem (GOLDFARB et al., 2021).

3 DIFERENÇAS ENTRE SSE-S3, SSE-KMS E SSE-C

As diferenças entre SSE-S3, SSE-KMS e SSE-C são os métodos de criptografia usados para proteger dados em repouso em serviços da AWS.

3.1 SSE-S3 (Server-Side Encryption with Amazon S3):

O SSE-S3 é um recurso oferecido pelo Amazon S3 para criptografar automaticamente os objetos armazenados em um bucket. Quando ativado, o Amazon S3 usa chaves criptográficas gerenciadas internamente para criptografar os objetos antes de armazená-los no disco. A criptografia é realizada de forma transparente, ou seja, o cliente não precisa fazer nada além de ativar o SSE-S3 no bucket. O Amazon S3 é responsável pela geração, rotação e proteção das chaves usadas na criptografia dos objetos (GOLDFARB et al., 2021).

3.2 SSE-KMS (Server-Side Encryption with AWS Key Management Service):

O SSE-KMS é um recurso semelhante ao SSE-S3, porém com a diferença de que a criptografia é realizada usando chaves gerenciadas pelo AWS Key Management Service (KMS). Ao usar o SSE-KMS, o Amazon S3 solicita ao KMS a geração de uma

chave de dados única para criptografar cada objeto antes de armazená-lo no disco. O KMS é responsável pela criação, rotação e gerenciamento das chaves de criptografia.

O SSE-KMS oferece maior controle sobre as chaves de criptografia, permitindo que os clientes gerenciem as políticas de acesso e monitorem o uso das chaves (GOLDFARB et al., 2021).

3.3 SSE-C (Server-Side Encryption with Customer-Provided Keys):

O SSE-C permite que o cliente forneça suas próprias chaves de criptografia para criptografar os objetos armazenados no Amazon S3. Com o SSE-C, o cliente é responsável por gerar, armazenar e gerenciar suas próprias chaves de criptografia. O cliente deve fornecer a chave de criptografia no momento em que o objeto é enviado para o Amazon S3, e o Amazon S3 usará essa chave para criptografar e descriptografar o objeto. Diferente do SSE-S3 e SSE-KMS, o Amazon S3 não tem conhecimento nem acesso às chaves de criptografia do cliente (GOLDFARB et al., 2021).

Em resumo, SSE-S3 é a opção mais simples, em que o Amazon S3 realiza a criptografia usando chaves gerenciadas internamente. SSE-KMS oferece um nível de controle adicional, permitindo que o cliente use chaves gerenciadas pelo KMS para criptografar os objetos. Já SSE-C permite que o cliente forneça suas próprias chaves de criptografia para o Amazon S3 usar na criptografia dos objetos. A escolha entre essas opções depende dos requisitos de segurança e controle do cliente em relação às chaves de criptografia (GOLDFARB et al., 2021).

4 AWS WAF (WEB APPLICATION FIREWALL)

- **Descrição:** O AWS WAF (Web Application Firewall) é um serviço de firewall de aplicativos da web que ajuda a proteger suas aplicações da web contra ameaças e ataques comuns, como injeção de SQL, cross-site scripting (XSS) e ataques de força bruta. Ele oferece uma camada adicional de segurança para a infraestrutura de aplicativos da web, ajudando a bloquear tráfego malicioso e indesejado antes que ele alcance suas aplicações.

O AWS WAF pode tratar o domínio de segurança de infraestrutura ao oferecer as seguintes funcionalidades e recursos:

- 1) Proteção contra ameaças: O WAF permite definir regras de segurança personalizadas para filtrar e bloquear solicitações maliciosas e indesejadas.

Ele permite criar regras de filtragem com base em padrões específicos, como strings, expressões regulares e características de tráfego, como endereço IP de origem. Isso ajuda a prevenir ataques de injeção de código, tentativas de acesso não autorizado e outros tipos de ataques comuns.

- 2) Regras gerenciadas: O AWS WAF também oferece um conjunto de regras gerenciadas prontas para uso, que são projetadas para proteger contra ameaças conhecidas e vulnerabilidades comuns. Essas regras são atualizadas regularmente pela AWS para lidar com as mais recentes ameaças de segurança. Os clientes podem selecionar e ativar as regras gerenciadas relevantes para suas aplicações, fornecendo uma camada adicional de proteção contra ameaças conhecidas.

- 3) Integração com outros serviços: O AWS WAF é altamente integrado com outros serviços da AWS, como o Amazon CloudFront (um serviço de entrega de conteúdo), o Application Load Balancer e o API Gateway. Isso permite a proteção das aplicações web em diferentes camadas, desde o tráfego de entrada até a camada de aplicação. A integração com esses serviços permite uma proteção abrangente e escalável para suas aplicações.

- 4) Monitoramento e registro: O WAF fornece recursos de monitoramento e registro, permitindo que você acompanhe o tráfego de entrada, monitore e analise as tentativas de ataques, e identifique possíveis vulnerabilidades em suas aplicações. Ele registra detalhes sobre as solicitações que correspondem às regras definidas, fornecendo informações valiosas para análise de segurança e investigação de incidentes. Ao utilizar o AWS WAF, as organizações podem proteger suas aplicações web contra ameaças e ataques comuns, mitigando

riscos e garantindo a disponibilidade e integridade de seus serviços online. O WAF oferece uma camada adicional de segurança na infraestrutura de aplicativos da web, ajudando a garantir a conformidade com padrões de segurança e a proteger os dados confidenciais dos usuários.

Em resumo, o AWS WAF é um serviço de firewall de aplicativos da web altamente eficaz que pode tratar o domínio de Segurança de Infraestrutura na certificação AWS Security Specialty. Ele fornece recursos avançados de proteção contra ameaças, filtragem de tráfego indesejado e monitoramento de solicitações para garantir a segurança e a disponibilidade de suas aplicações web. Ao utilizar o AWS WAF, as organizações podem fortalecer sua postura de segurança, mitigar riscos e proteger suas aplicações contra ameaças em constante evolução (GOLDFARB et al., 2021).

- **Caso de uso:** Use o AWS WAF para proteger seus aplicativos da web contra ataques maliciosos. Ele permite configurar regras de segurança para filtrar e bloquear tráfego indesejado, mantendo a integridade e a disponibilidade dos seus aplicativos (GOLDFARB et al., 2021).

4.1 WebACL

A Web ACL (Web Application Firewall) fornecida pelo serviço AWS WAF é uma camada de proteção essencial para aplicações web, ajudando a proteger contra ameaças e ataques maliciosos. O AWS WAF permite que você crie regras personalizadas para controlar o tráfego de entrada e saída da sua aplicação web, filtrando e bloqueando solicitações indesejadas ou potencialmente perigosas (GOLDFARB et al., 2021).

A importância da Web ACL fornecida pelo AWS WAF está diretamente relacionada à segurança das aplicações web. Ela ajuda a mitigar uma ampla variedade de ataques, como injeção de SQL, ataques de cross-site scripting (XSS), ataques de força bruta, entre outros. Ao definir regras e condições, é possível bloquear solicitações que correspondam a padrões específicos conhecidos por serem maliciosos ou suspeitos (GOLDFARB et al., 2021).

Uma das principais vantagens da AWS WAF é sua integração com a Open Web Application Security Project (OWASP). A OWASP é uma comunidade que desenvolve padrões de segurança para aplicações web. A AWS WAF inclui regras pré-configuradas baseadas nas melhores práticas da OWASP, o que ajuda a proteger automaticamente sua aplicação web contra muitos dos ataques comuns mencionados no Top 10 da OWASP (GOLDFARB et al., 2021).

Ao usar a Web ACL do AWS WAF, você pode definir regras personalizadas e adaptáveis às necessidades específicas da sua aplicação. Isso permite que você tenha um controle granular sobre o tráfego de entrada e saída, filtrando e bloqueando solicitações indesejadas. Além disso, o AWS WAF oferece recursos avançados, como proteção contra ataques de bots, mitigação de ataques de negação de serviço distribuídos (DDoS) e monitoramento em tempo real do tráfego (GOLDFARB et al., 2021).

Em resumo, a Web ACL fornecida pelo serviço AWS WAF é fundamental para garantir a segurança das aplicações web, ajudando a proteger contra ameaças e ataques maliciosos. Sua integração com a OWASP e suas capacidades de filtragem e bloqueio personalizáveis tornam o AWS WAF uma solução poderosa para mitigar riscos de segurança em ambientes web (GOLDFARB et al., 2021).

A figura “Ícone do AWS WAF (Web Application Firewall)” representa o ícone padrão da própria AWS para este serviço.

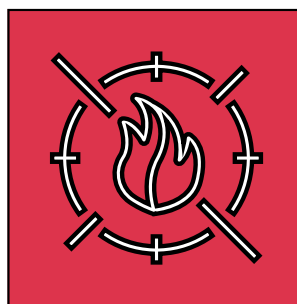


Figura 2 - Ícone do AWS WAF (Web Application Firewall)
Fonte: AWS (2023)

5 AWS SHIELD

- **Descrição:** O AWS Shield é um serviço de proteção contra ataques distribuídos de negação de serviço (DDoS) que ajuda a proteger os recursos

da AWS contra tráfego malicioso e volumétrico. Ele desempenha um papel crucial no domínio de Segurança de Infraestrutura, fornecendo proteção para garantir a disponibilidade dos recursos e a continuidade dos negócios em cenários de ataques DDoS. O AWS Shield pode tratar o domínio de segurança de infraestrutura ao oferecer as seguintes funcionalidades e recursos:

- 1) Mitigação de ataques DDoS: O AWS Shield fornece proteção avançada contra ataques DDoS que visam sobrecarregar seus recursos com tráfego malicioso. Ele utiliza algoritmos avançados de detecção e mitigação para identificar e filtrar o tráfego de ataque, garantindo que apenas o tráfego legítimo alcance seus recursos.
- 2) Proteção em camadas: O AWS Shield protege seus recursos em várias camadas, incluindo a camada de rede e a camada de aplicação. Ele oferece proteção integrada para serviços como o Amazon CloudFront (um serviço de entrega de conteúdo), o Elastic Load Balancer, o Amazon Route 53 (um serviço de DNS) e o Amazon Elastic Compute Cloud (EC2). Isso garante que seus recursos estejam protegidos em diferentes níveis, desde o tráfego de entrada até a camada de aplicação.
- 3) Monitoramento e alertas: O AWS Shield fornece recursos de monitoramento e alertas em tempo real para ajudar a detectar e responder a ataques DDoS. Ele registra informações detalhadas sobre os ataques, incluindo o tipo de ataque, a origem do tráfego malicioso e a duração do ataque. Isso permite que você monitore a saúde de seus recursos e tome medidas adequadas para mitigar os ataques.
- 4) Integração com outros serviços: O AWS Shield é altamente integrado com outros serviços da AWS, como o AWS CloudWatch e o AWS WAF. A integração com o AWS CloudWatch permite que você monitore métricas de tráfego e ativações de mitigação em tempo real, enquanto a integração com o AWS WAF permite uma proteção abrangente contra ataques DDoS e outras ameaças.

Ao utilizar o AWS Shield, as organizações podem proteger seus recursos da AWS contra ataques DDoS, garantindo a disponibilidade e a

continuidade dos negócios. Ele ajuda a reduzir a interrupção dos serviços, minimizando o impacto dos ataques DDoS e mantendo a operação normal dos recursos. Em resumo, o AWS Shield é um serviço essencial para a segurança de infraestrutura na AWS, fornecendo proteção contra ataques DDoS e garantindo a disponibilidade dos recursos. Ao utilizar o AWS Shield, as organizações podem fortalecer sua postura de segurança, mitigar riscos e proteger seus ativos na nuvem contra ameaças cibernéticas (GOLDFARB et al., 2021).

- **Caso de uso:** Use o AWS Shield para proteger seus aplicativos e recursos da AWS contra ataques DDoS. Ele oferece proteção automática e personalizada para ajudar a mitigar e responder a ataques em tempo real (GOLDFARB et al., 2021).

A figura “Ícone do AWS Shield” representa o ícone padrão da própria AWS para este serviço.

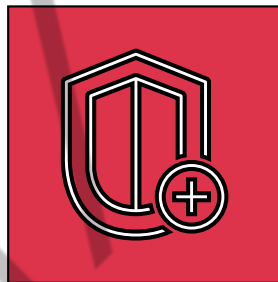


Figura 3 - Ícone do AWS Shield
Fonte: AWS (2023)

6 AWS SECURITY HUB

- **Descrição:** O AWS Security Hub é um serviço de segurança e conformidade que fornece uma visão abrangente do estado da segurança de suas cargas de trabalho na AWS. Ele oferece uma interface centralizada para visualizar, monitorar e gerenciar as descobertas de segurança em toda a sua infraestrutura. O AWS Security Hub desempenha um papel importante no domínio de Segurança de Infraestrutura, permitindo identificar e remediar vulnerabilidades, ameaças e configurações incorretas em tempo real.

O AWS Security Hub pode tratar o domínio de Segurança de Infraestrutura ao oferecer as seguintes funcionalidades e recursos:

- 1) Centralização de descobertas: O Security Hub coleta e consolida automaticamente os resultados de verificações de segurança de vários serviços da AWS, como Amazon GuardDuty, AWS Inspector e AWS Macie. Ele fornece uma exibição centralizada de todas as descobertas de segurança, permitindo que você identifique facilmente as áreas de risco e tome medidas corretivas.
- 2) Priorização e classificação de descobertas: O Security Hub classifica automaticamente as descobertas com base em sua gravidade e impacto potencial, permitindo que você priorize as ações corretivas. Ele também fornece detalhes sobre a natureza da descoberta, facilitando a compreensão do problema e a tomada de decisões informadas.
- 3) Integração com serviços de terceiros: O Security Hub oferece integração com parceiros de segurança terceirizados, permitindo que você importe e visualize descobertas de segurança de outras soluções de segurança. Isso permite uma visão abrangente e centralizada da postura de segurança de suas cargas de trabalho, independentemente do fornecedor ou tecnologia utilizada.
- 4) Automação e remediação: O Security Hub permite a automação de ações corretivas por meio da integração com serviços como AWS Systems Manager Automation e AWS Lambda. Isso facilita a implementação de fluxos de trabalho automatizados para resolver problemas de segurança, como aplicar patches, reconfigurar permissões ou isolar recursos comprometidos.
- 5) Painéis de conformidade: O Security Hub fornece painéis de conformidade pré-configurados que permitem monitorar a conformidade com padrões de segurança e regulamentações, como o AWS Foundational Security Best Practices, o CIS AWS Foundations Benchmark e o PCI DSS. Isso ajuda a garantir que suas cargas de trabalho atendam aos requisitos de segurança exigidos. Ao utilizar o AWS Security Hub, as organizações podem ter uma visão unificada da

segurança de suas cargas de trabalho na AWS, identificar rapidamente problemas de segurança e tomar ações corretivas para garantir a integridade e a conformidade de seus sistemas.

Em resumo, o AWS Security Hub é um serviço valioso para a segurança de infraestrutura na AWS, fornecendo uma visão centralizada e abrangente das descobertas de segurança. Ao utilizar o Security Hub, as organizações podem aumentar a eficiência na identificação e resposta a ameaças de segurança, melhorar a conformidade com padrões de segurança e garantir a integridade de suas cargas de trabalho na nuvem (PIERCE et al., 2021).

- **Caso de uso:** Use o Security Hub para consolidar e visualizar informações de segurança de vários serviços da AWS. Ele permite identificar rapidamente problemas de segurança, priorizar ações de remediação e manter a conformidade com os padrões de segurança (PIERCE et al., 2021).

A figura “Ícone do AWS Security Hub” representa o ícone padrão da própria AWS para este serviço.

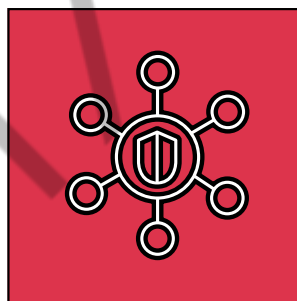


Figura 4 - Ícone do AWS Security Hub
Fonte: AWS (2023)

7 AMAZON VPC (VIRTUAL PRIVATE CLOUD)

- **Descrição:** O Amazon Virtual Private Cloud (VPC) é um serviço que permite criar e gerenciar redes virtuais isoladas na AWS. Ele desempenha um papel fundamental no domínio de Segurança de Infraestrutura, fornecendo uma camada de isolamento e controle sobre os recursos na nuvem, garantindo a segurança e a proteção dos dados. O Amazon VPC pode tratar o domínio

de segurança de infraestrutura ao oferecer as seguintes funcionalidades e recursos:

- 1) Isolamento de rede: Com o Amazon VPC, é possível criar redes virtuais isoladas logicamente na nuvem. Cada VPC pode ser configurado com seu próprio conjunto de sub-redes, tabelas de roteamento e gateways, permitindo separar e isolar recursos específicos em uma rede privada virtual.
- 2) Controle de acesso: O Amazon VPC oferece controle granular sobre o acesso aos recursos da rede. É possível configurar grupos de segurança, que atuam como firewalls virtuais, para controlar o tráfego de entrada e saída das instâncias EC2 dentro do VPC.

Além disso, é possível criar listas de controle de acesso de rede (Network Access Control Lists - NACLs) para definir regras de tráfego em nível de sub-rede.

- 3) Conectividade segura: O Amazon VPC permite estabelecer conexões seguras com outros recursos na nuvem e com o ambiente local. Por exemplo, é possível estabelecer conexões VPN (Virtual Private Network) ou usar o serviço AWS Direct Connect para criar links dedicados entre a infraestrutura local e o VPC, garantindo comunicações seguras.
- 4) Filtragem de tráfego: O Amazon VPC oferece suporte à filtragem de tráfego de rede usando listas de controle de acesso de rede (NACLs) e grupos de segurança. Essas configurações permitem definir regras de tráfego permitido ou bloqueado em nível de sub-rede e em nível de instância, ajudando a proteger contra tráfego indesejado ou malicioso.
- 5) Monitoramento e registro: O Amazon VPC oferece recursos de monitoramento e registro de tráfego. É possível habilitar o Amazon VPC Flow Logs para capturar informações sobre o tráfego de rede em suas sub-redes, fornecendo insights valiosos para análise de segurança, detecção de anomalias e investigação de incidentes. Ao utilizar o Amazon VPC, as organizações podem projetar e implantar uma infraestrutura de rede segura na AWS, isolando recursos e controlando

o acesso ao tráfego de rede. O VPC fornece um ambiente confiável para executar aplicações, garantindo a segurança e a integridade dos dados.

Em resumo, o Amazon Virtual Private Cloud (VPC) é um serviço essencial para a segurança de infraestrutura na AWS, fornecendo controle granular sobre a rede e isolamento de recursos. Ao utilizar o VPC, as organizações podem criar uma infraestrutura de rede segura, controlar o acesso aos recursos e proteger o tráfego de rede, garantindo a segurança e a proteção dos dados na nuvem (PIERCE et al., 2021).

- **Caso de uso:** Use o Amazon VPC para criar uma rede virtual privada isolada para suas instâncias e recursos na AWS. Ele fornece uma camada adicional de segurança, permitindo que você defina regras de firewall (*security groups*) para controlar o acesso aos recursos (PIERCE et al., 2021).

A figura “Ícone do Amazon Virtual Private Cloud (VPC)” representa o ícone padrão da própria AWS para este serviço.

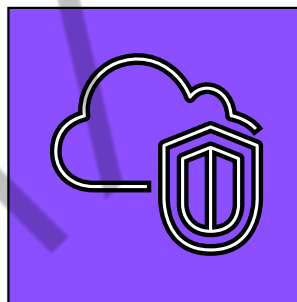


Figura 5 - Ícone do Amazon Virtual Private Cloud (VPC)
Fonte: AWS (2023)

Além disso, outros serviços da AWS que podem ser usados para tratar este domínio em específico foram explicados nos: Capítulo 1 – Reposta a incidentes e Capítulo 2 – Registro em log e monitoramento deste Curso. De forma resumida, são os serviços:

- AWS IAM (Identity and Access Management) que permite que você gerencie de forma granular as identidades e permissões de acesso aos recursos da AWS. Com o IAM, você pode criar e gerenciar usuários, grupos e funções, atribuir permissões específicas e implementar políticas de segurança para controlar o acesso aos recursos. Isso ajuda a garantir que

apenas as pessoas autorizadas tenham acesso aos recursos e protege contra ameaças internas (PIERCE et al., 2021).

- AWS CloudTrail que é um serviço que registra continuamente as ações realizadas nas contas da AWS. Ele fornece registros detalhados de atividades, incluindo ações de gerenciamento de identidade e acesso, criação e modificação de recursos, e eventos de segurança relevantes. Com o CloudTrail, você pode monitorar e auditar as atividades em sua conta, detectar comportamentos suspeitos, analisar incidentes de segurança e garantir a conformidade com regulamentações (PIERCE et al., 2021).
- AWS Config que é um serviço que permite avaliar, auditar e registrar a configuração de seus recursos da AWS. Ele fornece um inventário detalhado dos recursos, histórico de alterações e verificações contínuas para identificar configurações não conformes.

Com o Config, você pode monitorar a conformidade das configurações, identificar e corrigir desvios de segurança, e automatizar a avaliação e o gerenciamento das configurações em sua infraestrutura (PIERCE et al., 2021).

- Amazon GuardDuty que é um serviço de detecção de ameaças gerenciado que monitora continuamente suas contas e cargas de trabalho da AWS em busca de atividades maliciosas ou não autorizadas. Ele utiliza algoritmos de machine learning e análise comportamental para identificar possíveis ameaças, como atividades de hacking, exploração de vulnerabilidades e comportamentos de malware. O GuardDuty fornece alertas em tempo real sobre atividades suspeitas, permitindo uma resposta rápida e eficiente a incidentes de segurança (PIERCE et al., 2021).

Em conjunto, esses serviços desempenham um papel crucial no domínio de Segurança de Infraestrutura, fornecendo controle de acesso, rastreamento de atividades, monitoramento de configurações e detecção de ameaças. Eles ajudam a proteger seus recursos da AWS, garantir a conformidade, identificar e responder a incidentes de segurança, e fortalecer a postura geral de segurança em sua infraestrutura na nuvem.

8 EXEMPLOS PRÁTICOS (HANDS-ON)

Realizar estudos práticos hands-on desempenha um papel fundamental na assimilação dos conhecimentos em ambientes de nuvem, especialmente na AWS. Por meio da prática direta, os alunos podem aplicar os conceitos teóricos em situações reais, ganhando experiência prática na configuração e no gerenciamento de serviços em nuvem. Para aproveitar ao máximo essa experiência, **é necessário que o aluno possua sua própria conta AWS**. Isso permite que eles tenham total controle sobre seu ambiente de estudo, experimentem diferentes configurações e se familiarizem com a interface e as ferramentas da AWS. No entanto, é importante ressaltar que o uso da AWS está sujeito a custos. Durante os estudos práticos, o aluno pode incorrer em despesas em sua conta AWS, que serão cobradas em seu cartão de crédito. Portanto, é imprescindível que o aluno esteja ciente desses custos potenciais e tome medidas para monitorar e controlar os gastos, estabelecendo limites e configurando alertas para evitar surpresas indesejadas na fatura do cartão de crédito.

8.1 Criptografia de dados com AWS Key Management Service (KMS)

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Key Management Service (KMS) relacionado ao Domínio 3: Segurança de infraestrutura:

Passo 1 - Criação de uma chave

1. Acesse o Console de Gerenciamento da AWS em <https://console.aws.amazon.com>.

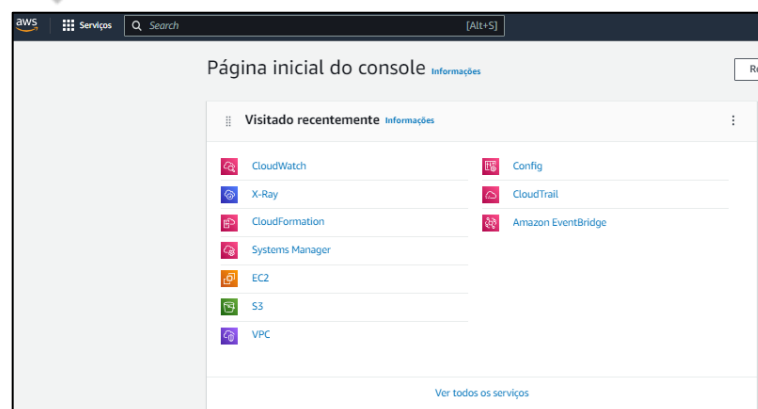


Figura 6 - Acesso a console de gerenciamento da AWS
Fonte: Elaborador pelo autor (2023)

2. Navegue até o serviço AWS Key Management Service (KMS).

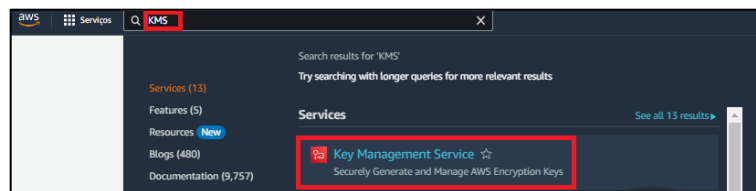


Figura 7 - Acessando serviços KMS
Fonte: Elaborador pelo autor (2023)

3. Na página do serviço “Key Management Service (KMS)”, clique em “Chaves gerenciadas pelo cliente”.

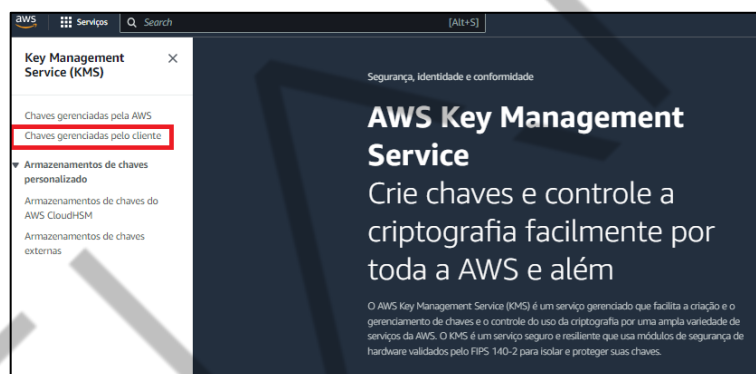


Figura 8 - Acessar Chaves gerenciadas pelo cliente
Fonte: Elaborador pelo autor (2023)

4. Na página “Chaves gerenciadas pelo cliente”, clique no botão “Criar chave”.

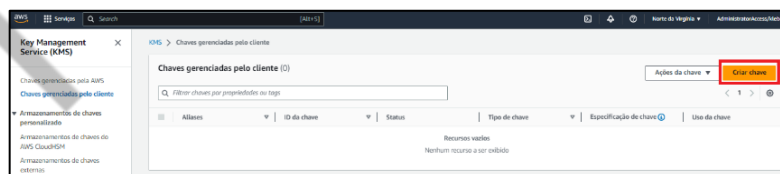


Figura 9 - Iniciar criação de chave gerenciada pelo cliente
Fonte: Elaborador pelo autor (2023)

5. Na “Etapa 1 – Configurar chave”, aceite as opções que vieram marcadas por padrão e clique no botão “Próximo”.

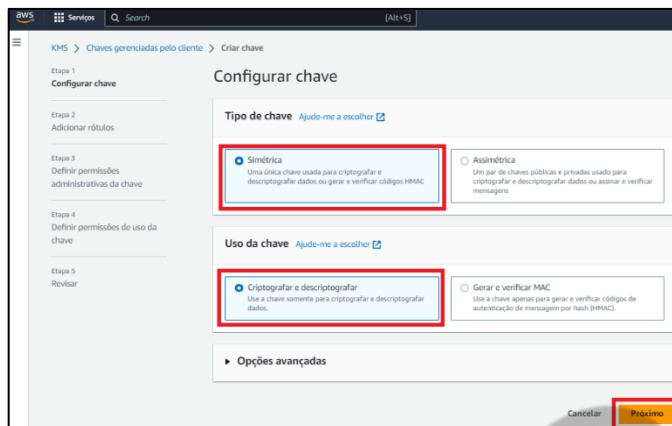


Figura 10 - Etapa 1 - Configurar Chave
Fonte: Elaborador pelo autor (2023)

6. Na “Etapa 2 – Adicionar rótulos”, aceite as opções que vieram marcadas por padrão, mas insira um “Alias” para sua chave, por exemplo, “alunokey” e clique no botão “Próximo”.

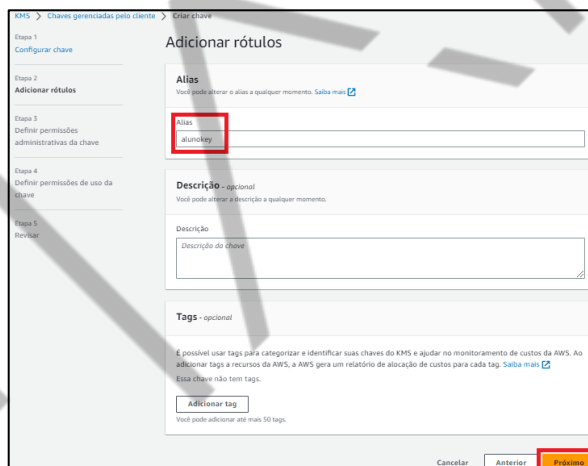


Figura 11 - Etapa 2 - Configurar rótulos
Fonte: Elaborador pelo autor (2023)

7. Na “Etapa 3 – Definir permissões administrativas da chave”, escolha quais usuários podem administrar essa chave, e clique no botão “Próximo”.

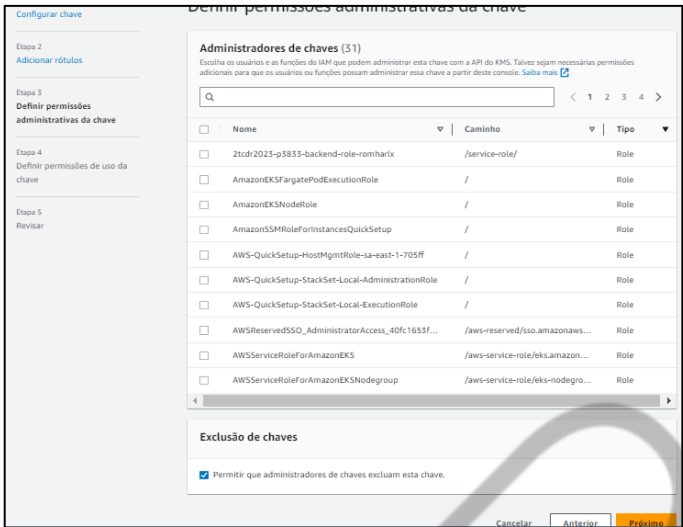


Figura 12 - Etapa 3 - Definir permissões administrativas da chave
Fonte: Elaborador pelo autor (2023)

8. Na “Etapa 4 – Definir permissões de uso da chave”, escolha quais usuários podem usar essa chave, e clique no botão “Próximo”.

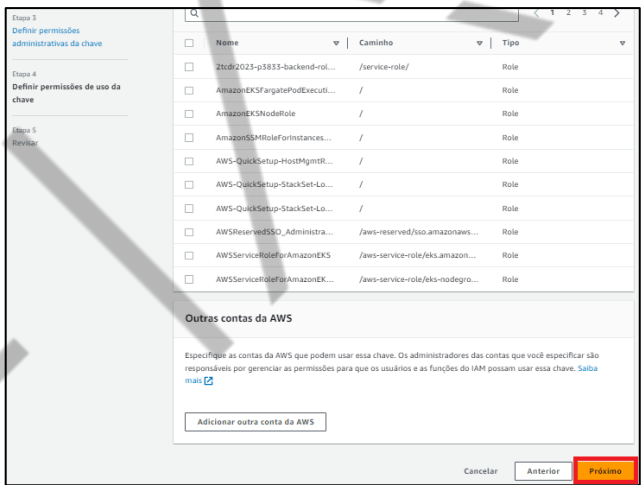
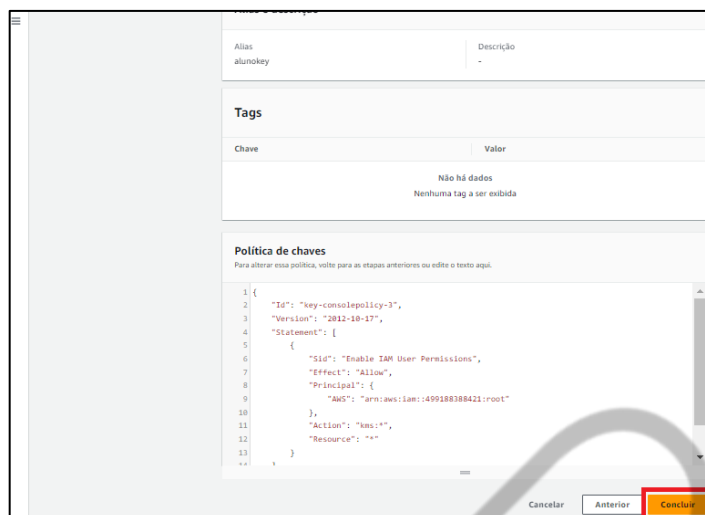


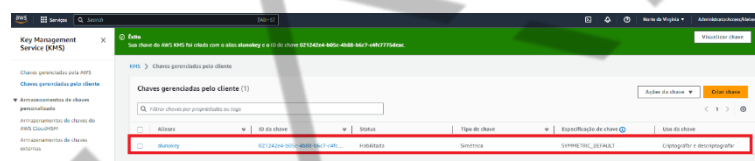
Figura 13 - Etapa 4 - Definir permissões de uso da chave
Fonte: Elaborador pelo autor (2023)

9. Na “Etapa 5 – Revisar”, revise todas as opções anteriores e clique no botão “Concluir”.



Fonte: Elaborador pelo autor (2023)

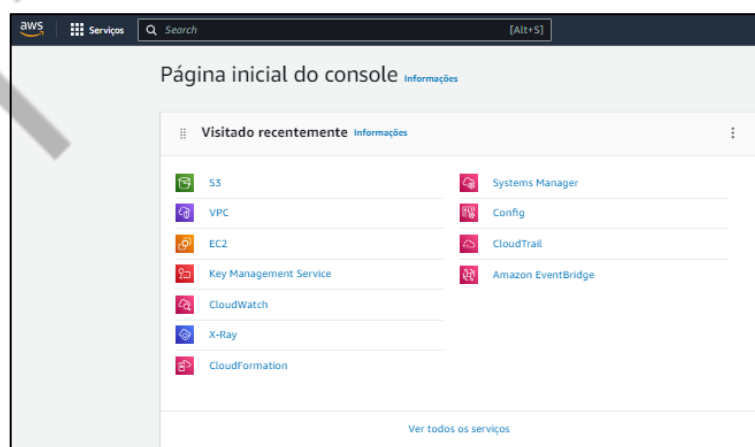
10. Após concluir essas etapas, a chave aparecerá criada, conforme a figura abaixo.



Fonte: Elaborador pelo autor (2023)

Passo 2 - Uso da chave

1. Agora que você criou a chave, volte na tela inicial da console da AWS.



Fonte: Elaborador pelo autor (2023)

2. Navegue até o serviço da AWS que deseja usar a criptografia com o KMS, como o Amazon S3.

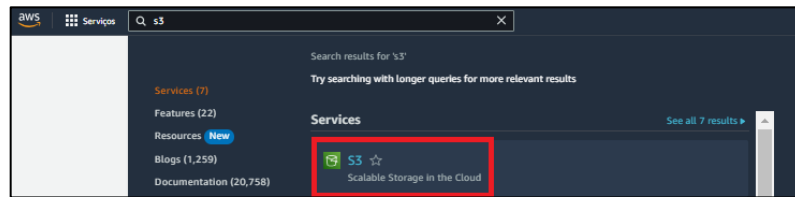


Figura 17 - Acessando o serviço S3
Fonte: Elaborador pelo autor (2023)

3. Na página “Amazon S3”, clique em “Buckets”.

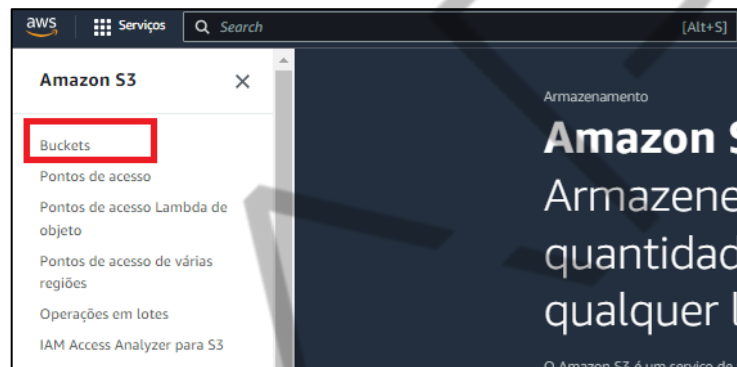


Figura 18 - Criando Bucket no Amazon S3 parte 1
Fonte: Elaborador pelo autor (2023)

4. Na página “Buckets”, clique no botão “Criar Bucket”.

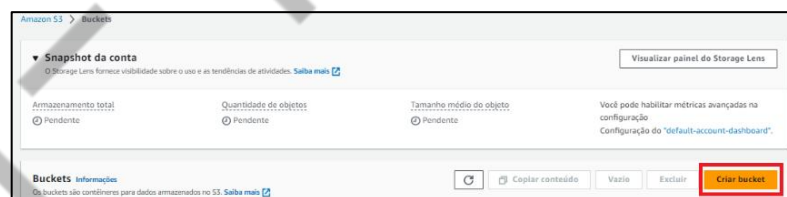


Figura 19 - Criando Bucket no Amazon S3 parte 2
Fonte: Elaborador pelo autor (2023)

5. Na página “Criar Bucket”, preencha o campo “Nome do Bucket” com um valor que você preferir, observando que o “Nome do Bucket” deve ser único em toda AWS, portanto, não se surpreenda se você escolher um nome que já exista, conforme a figura abaixo

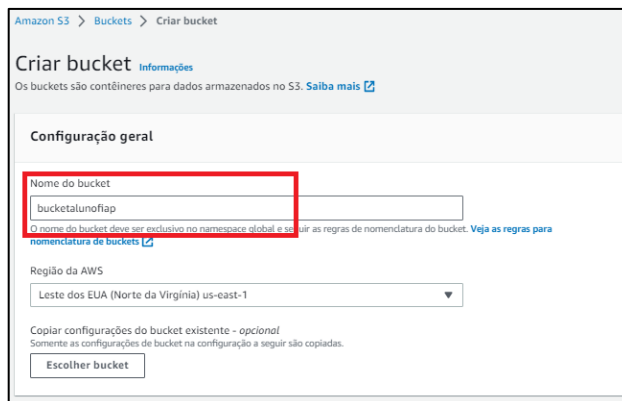


Figura 20 - Criação de Bucket - Passagem de Parâmetros - Parte 1
Fonte: Elaborador pelo autor (2023)

6. Ainda na página “Buckets”, aceite todas as opções por padrão com exceção da seção “Criptografia padrão”; Nesta seção, selecione a opção "Criptografia do lado do servidor com chaves do AWS Key Management Service (SSE-KMS)" e, em seguida, na “Chave do AWS KMS” e deixe a opção “Chave do bucket” em “Ativar”, escolha a chave KMS que foi criada no passo 1.

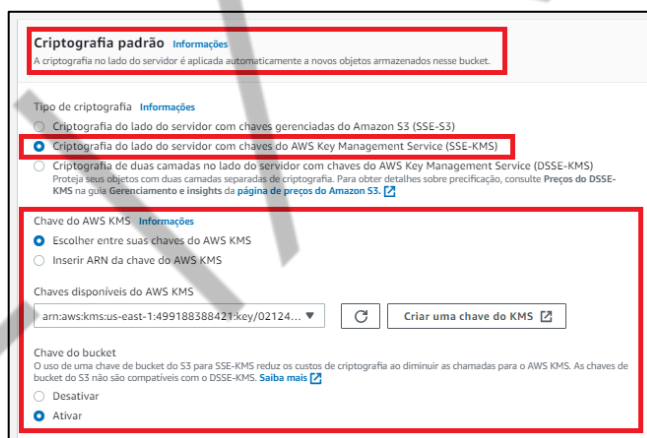


Figura 21 - Criação de Bucket - Passagem de Parâmetros - Parte 2
Fonte: Elaborador pelo autor (2023)

7. Por fim, ainda na página “Buckets”, clique no botão “Criar bucket”.

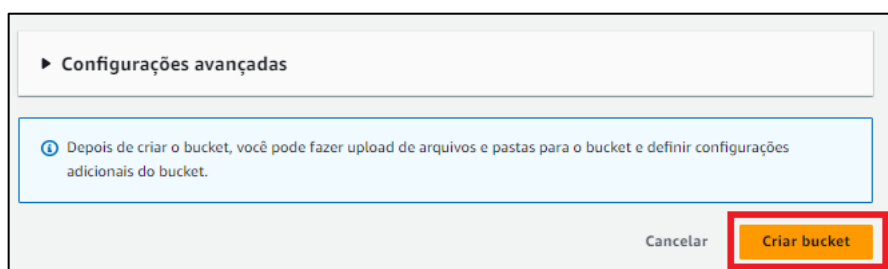


Figura 22 - Finalização da criação do bucket criptografado
Fonte: Elaborador pelo autor (2023)

8. Logo após finalizar a criação do bucket, a console voltará para a página de “Buckets” e você poderá verificar que o bucket foi criado.

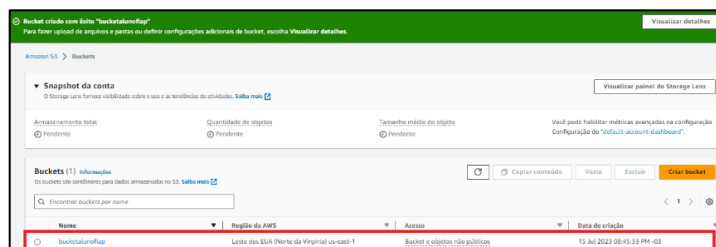


Figura 23 - Validação da criação do Bucket
Fonte: Elaborador pelo autor (2023)

9. Clique no link do “Bucket” para acessar o bucket em si, após isso, clique na seção “Propriedades”.

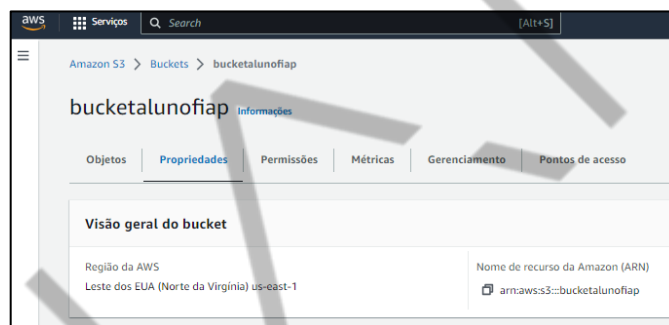


Figura 24 - Propriedades do Bucket
Fonte: Elaborador pelo autor (2023)

10. Ainda na seção “Propriedades”, procure a subseção “Criptografia padrão” e valide que o bucket está sendo criptografado com a chave que você criou.



Figura 25 - Validação do bucket criptografado com a chave
Fonte: Elaborador pelo autor (2023)

Agora você configurou o AWS Key Management Service (KMS) para criar uma chave mestra e usá-la para criptografar dados na sua infraestrutura da AWS. O KMS oferece um controle seguro e centralizado sobre as chaves de criptografia, permitindo que você proteja seus dados sensíveis armazenados nos serviços da AWS.

Certifique-se de revisar regularmente as permissões de acesso e as políticas de chave para garantir que apenas usuários autorizados tenham acesso às chaves e aos dados criptografados. Isso ajuda a garantir a confidencialidade e a integridade dos seus dados na nuvem.

8.2 Proteção de aplicação com AWS WAF (Web Application Firewall)

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS WAF (Web Application Firewall) relacionado ao domínio 3 - segurança de infraestrutura:

Passo 1 - Criação de um conjunto de regras

1. Acesse novamente a console da AWS.

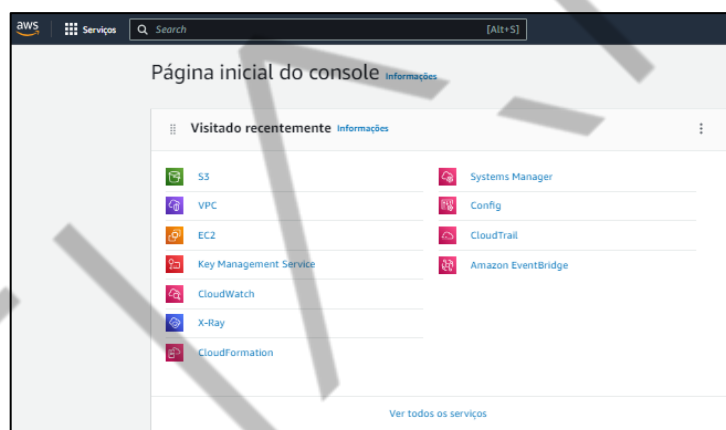


Figura 26 - Console de gerenciamento da AWS
Fonte: Elaborador pelo autor (2023)

2. Procure pelo serviço WAF e acesse “WAF & Shield”.

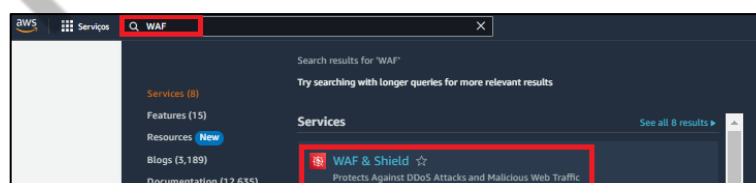


Figura 27 - Acessando serviço WAF
Fonte: Elaborador pelo autor (2023)

3. Na página de “WAF & Shield”, clique em WEB ACLs, conforme figura abaixo.

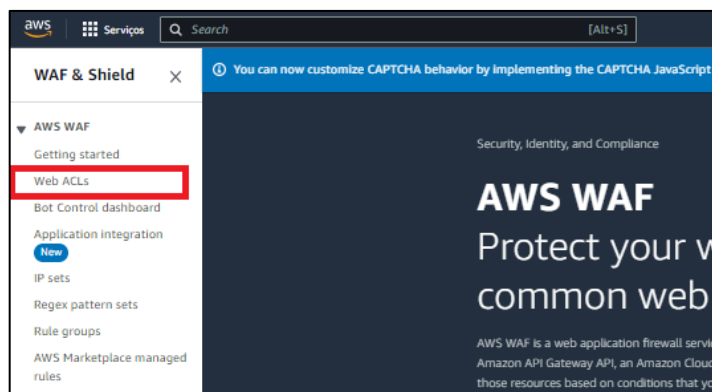


Figura 28 - Acessando Web ACLs
Fonte: Elaborador pelo autor (2023)

4. Na página de “Web ACLs”, clique no botão “Create Web ACL”.

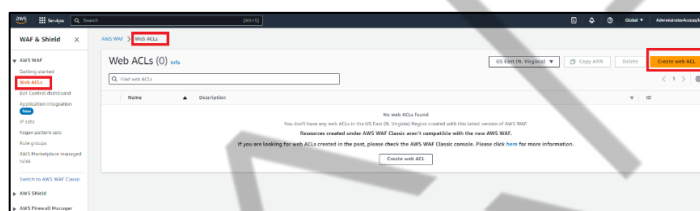


Figura 29 - Criando Web ACL no WAF & Shield
Fonte: Elaborador pelo autor (2023)

Atenção: A página de “Create Web ACL”, mesmo configurando o idioma da console da AWS para Português-Brasil (PT-BR), ficará na língua inglesa.

5. Na página “Create web ACL”, na Etapa 1 e na seção “Web ACL details”, informe um valor no campo “Name”, por exemplo, “alunofiapwebacl”. Em seguida, na seção “Resource type”, escolha a opção “Amazon CloudFront distributions”.

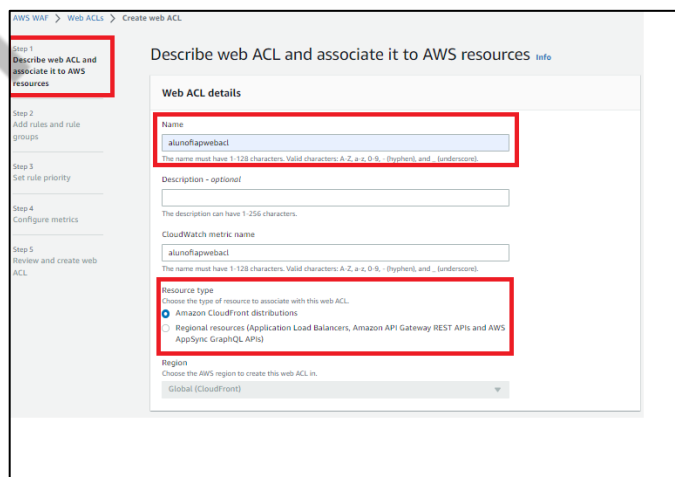


Figura 30 - Etapa 1 - Criação Web ACL - Parte 1
Fonte: Elaborador pelo autor (2023)

6. Ainda, na página “Create web ACL”, na Etapa 1 e na seção “Web ACL details”, deixa as outras opções como padrão e clique em “Next”.

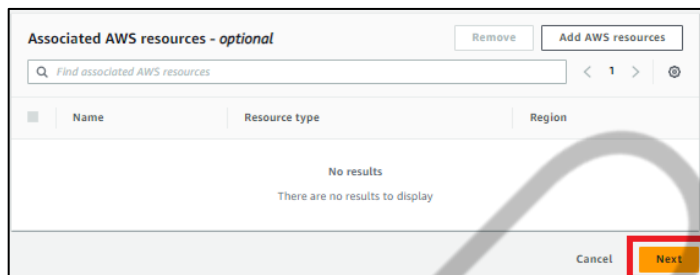


Figura 31 - Etapa 1 - Criação Web ACL - Parte 2
Fonte: Elaborador pelo autor (2023)

7. Na página “Create web ACL”, na Etapa 1, na seção “Add rules and rule groups”, e na subseção “Rules, clique no botão “Add Rules”.

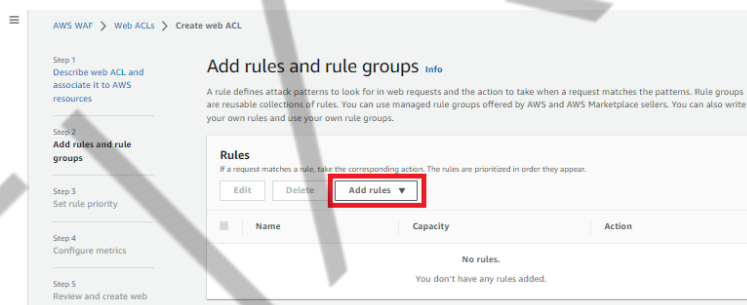


Figura 32 - Etapa 1 - Adicionar Regras - Parte 3
Fonte: Elaborador pelo autor (2023)

8. Na página “Add managed rule groups”, expanda a subseção “AWS managed rule groups”, e ative a opção “Core rule set” – essas regras estão aderentes com publicações da OWASP.

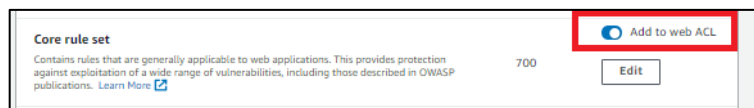


Figura 33 - Ativar Core rule set
Fonte: Elaborador pelo autor (2023)

9. Ainda na página “Add managed rule groups”, clique no botão “Add rules”.

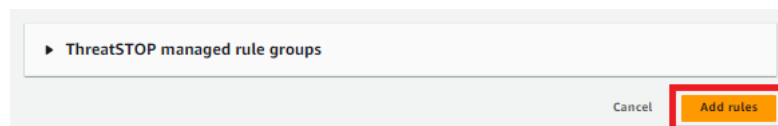


Figura 34 - Adicionar regras
Fonte: Elaborador pelo autor (2023)

10. De volta a página “Create web ACL”, na Etapa 2, clique no botão “Next”.

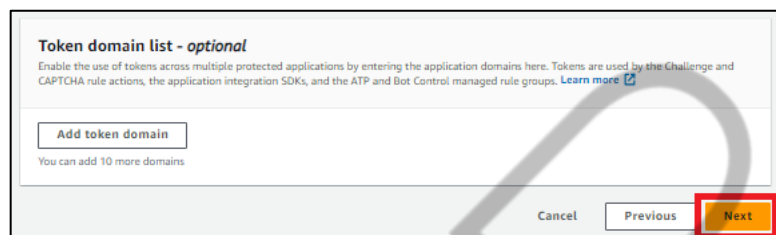


Figura 35 - Etapa 2 - Conclusão
Fonte: Elaborador pelo autor (2023)

11. Na página “Set rule priority”, na Etapa 3, clique no botão “Next”.

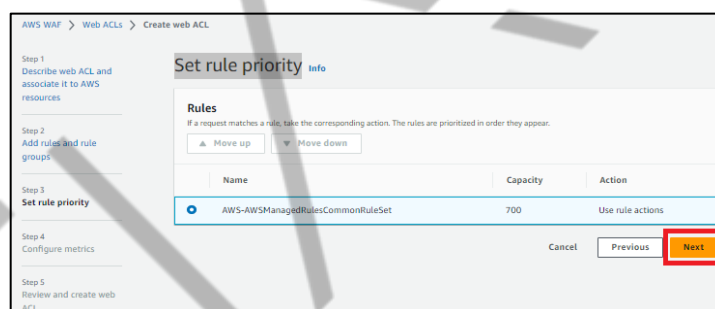


Figura 36 - Etapa 3 - Conclusão
Fonte: Elaborador pelo autor (2023)

12. Na página “Configure metrics”, na Etapa 4, clique no botão “Next”.

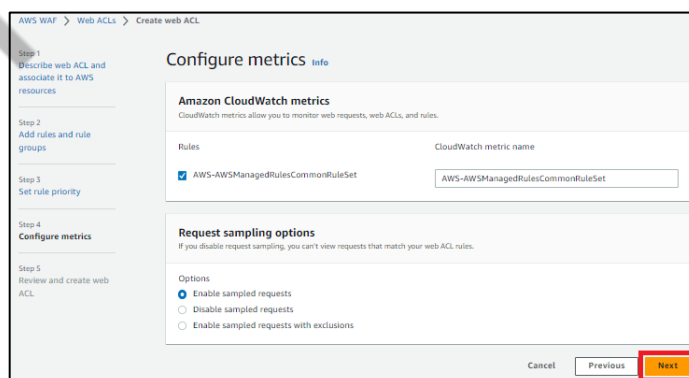


Figura 37 - Etapa 4 - Conclusão
Fonte: Elaborador pelo autor (2023)

13. Na página “Review and create web ACL”, na Etapa 4, clique no botão “Create web ACL”.

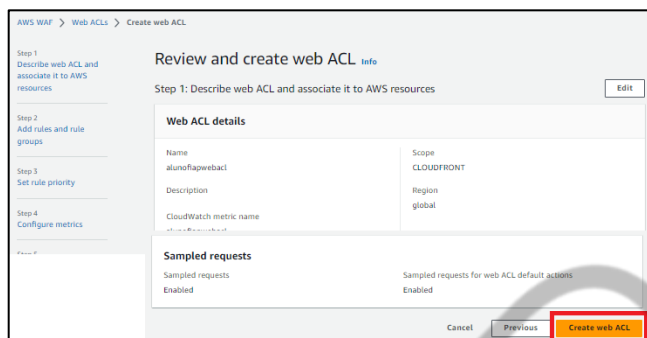


Figura 38 - Etapa 5 - Conclusão
Fonte: Elaborador pelo autor (2023)

14. De volta a página “Web ACLs” do “AWS WAF”, verifique se a Web ACL foi criada corretamente.

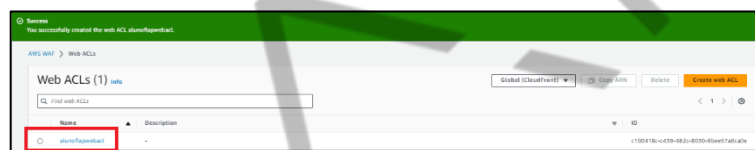


Figura 39 - Validação da criação da Web ACL
Fonte: Elaborador pelo autor (2023)

Passo 2 - Utilização do WAF com Amazon CloudFront.

1. Volte novamente para a “Página inicial do console”.

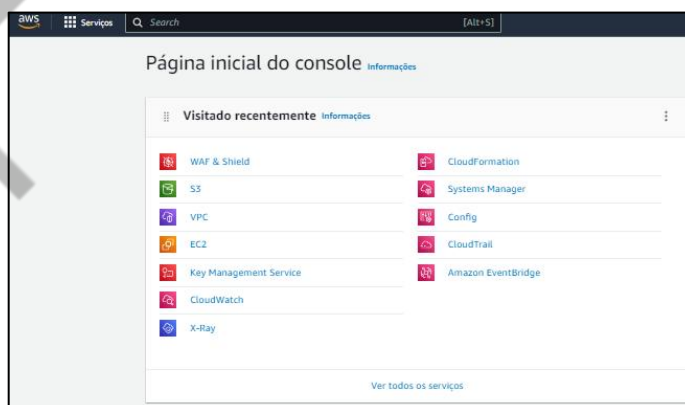


Figura 40 - Página inicial do console
Fonte: Elaborador pelo autor (2023)

2. Procure pelo serviço “CloudFront”.

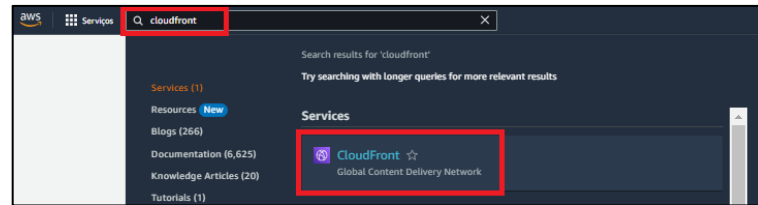


Figura 41 - Acessando o serviço CloudFront
Fonte: Elaborador pelo autor (2023)

3. Na página do “CloudFront”, clique em “Distributions”.

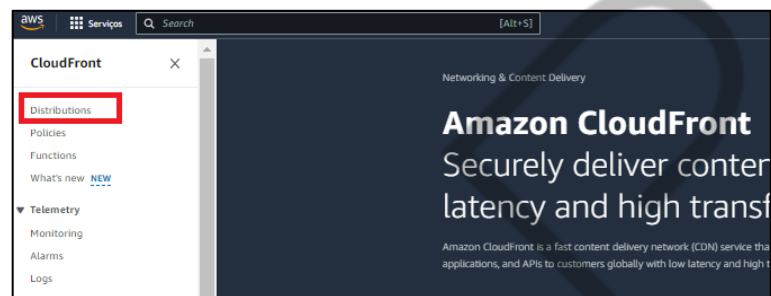


Figura 42 - Acessando Distribuições do CloudFront
Fonte: Elaborador pelo autor (2023)

4. Na página “Distributions”, clique no botão “Create distribution”.

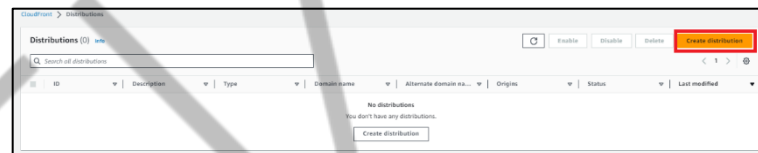


Figura 43 - Iniciando a criação de Distribuições
Fonte: Elaborador pelo autor (2023)

5. Na página “Create Distribution”, na seção “Origin Domain”, escolha uma origem de tráfego, por exemplo um bucket s3.

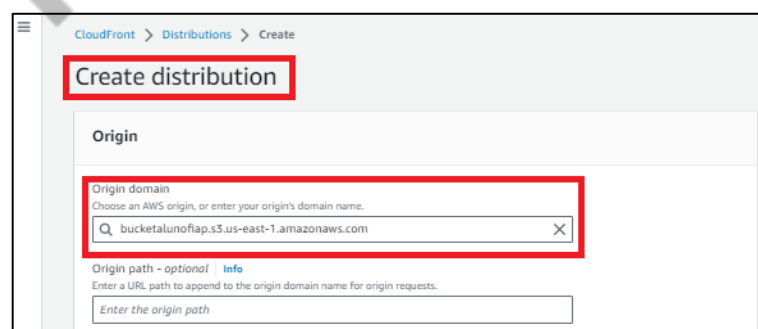


Figura 44 - Criação de Distribuição no CloudFront - Parte 1
Fonte: Elaborador pelo autor (2023)

6. Ainda na página “Create Distribution”, na seção “Web Application Firewall (WAF)”, escolha a opção “Enable security protections”, em seguida ative a opção “Use existing WAF configuration”, e na subseção “Choose a web ACL”, selecione a Web ACL criada no passo anterior.

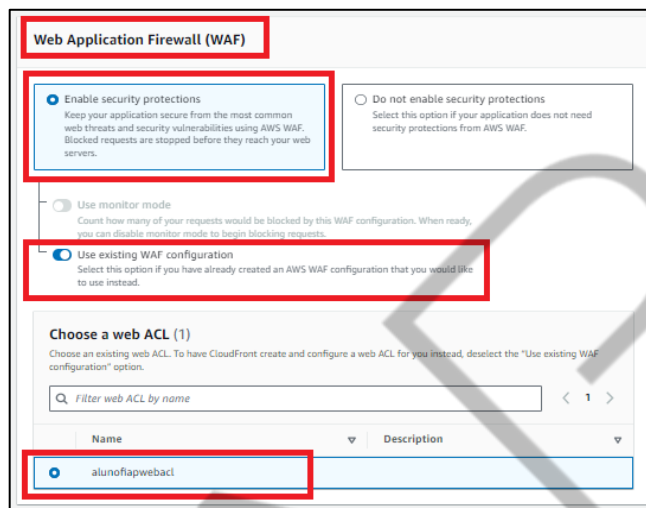


Figura 45 - Criação de Distribuição no CloudFront - Parte 2
Fonte: Elaborador pelo autor (2023)

7. Por fim, ainda na página “Create Distribution”, mantenha todas as outras configurações de seções e subseções de forma padrão, ou seja, não realize nenhuma alteração e clique no botão “Create distribution”.

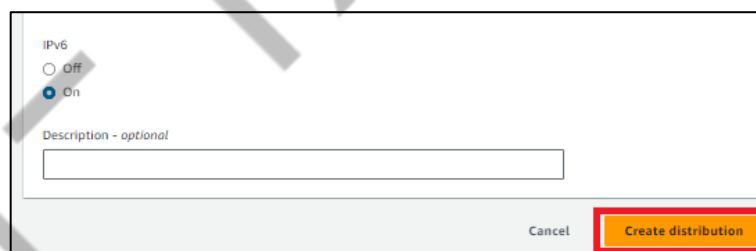


Figura 46 - Criação de Distribuição no CloudFront - Parte 3
Fonte: Elaborador pelo autor (2023)

8. Após isso, confirme que sua distribuição CloudFront foi criada com sucesso.

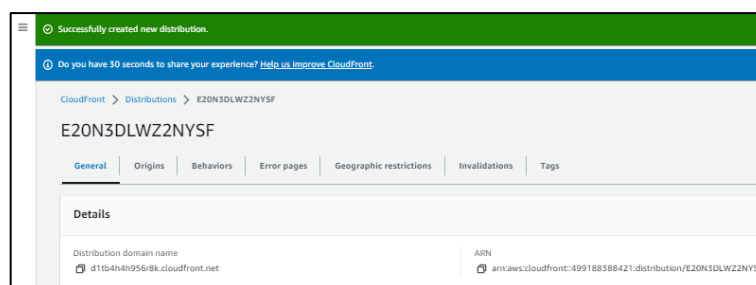


Figura 47 - Confirmação da criação da distribuição CloudFront
Fonte: Elaborador pelo autor (2023)

Agora você configurou o AWS WAF para proteger sua aplicação web contra ataques e ameaças. O WAF oferece uma camada adicional de segurança ao filtrar e bloquear o tráfego indesejado.

9 DESAFIOS

Realizar desafios práticos no estudo para a certificação AWS Security Specialty (SCS-C01) desempenha um papel fundamental na assimilação e compreensão dos conhecimentos necessários. Essa abordagem prática permite que você aplique os conceitos teóricos em situações reais, desenvolvendo habilidades práticas e aumentando sua confiança na resolução de problemas relacionados à segurança em ambientes de nuvem.

Os desafios práticos envolvem a realização de tarefas e cenários simulados, nos quais você terá a oportunidade de lidar com situações de segurança em tempo real. Esses desafios geralmente são baseados em casos de uso reais e abrangem vários aspectos do domínio de segurança da AWS, como resposta a incidentes, registro de logs, gerenciamento de identidade e acesso, entre outros.

Ao realizar desafios práticos, você terá a oportunidade de colocar em prática os conceitos aprendidos, ganhando experiência prática com os serviços e recursos da AWS. Isso ajuda a consolidar seu conhecimento teórico, pois você enfrentará desafios específicos que exigem a aplicação dos princípios de segurança em ambientes de nuvem.

Além disso, os desafios práticos proporcionam um ambiente de aprendizado interativo, onde você pode experimentar diferentes configurações, testar cenários e explorar soluções para problemas complexos. Isso promove o pensamento crítico e a capacidade de resolver problemas de segurança em tempo real.

É importante ressaltar que realizar desafios práticos requer uma conta AWS ativa e a disposição para investir tempo e recursos. Esses desafios podem envolver a criação de recursos, a configuração de serviços e até mesmo a simulação de ataques e incidentes de segurança. Portanto, é essencial ter uma compreensão clara das

implicações financeiras e garantir que você esteja ciente dos custos potenciais associados ao uso dos serviços AWS durante esses desafios práticos.

Os desafios práticos oferecem uma maneira eficaz de aprimorar seus conhecimentos em segurança na nuvem, permitindo que você ganhe confiança e desenvolva habilidades práticas essenciais para enfrentar os desafios da segurança em ambientes de nuvem. Ao aplicar os conceitos em situações reais, você estará preparado para lidar com os desafios complexos que podem surgir na implantação e gerenciamento de infraestruturas de nuvem seguras na AWS.

9.1 Controle de autenticação de usuários com AWS Identity and Access Management (IAM)

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Identity and Access Management (IAM) relacionado ao Domínio 3: Segurança de infraestrutura:

Passo 1- Acesso ao console de gerenciamento da AWS

1. Acesse o Console de Gerenciamento da AWS em <https://console.aws.amazon.com>.
2. Faça login usando suas credenciais de administrador.

Passo 2 - Criação de grupo no IAM

1. Navegue até o serviço AWS IAM no Console de Gerenciamento da AWS.
2. Clique em "Grupos" no painel de navegação esquerdo.
3. Clique em "Criar grupo".
4. Forneça um nome descritivo para o grupo, como "Administradores".
5. Clique em "Avançar para permissões".
6. Selecione as políticas de permissão desejadas para o grupo. Por exemplo, você pode selecionar a política "AdministratorAccess" para conceder permissões de administrador completo.
7. Clique em "Avançar para revisar".
8. Revise as informações do grupo e clique em "Criar grupo".

Passo 3 - Criação de usuário no IAM

1. Navegue até o serviço AWS IAM no Console de Gerenciamento da AWS.
2. Clique em "Usuários" no painel de navegação esquerdo.
3. Clique em "Adicionar usuário".
4. Forneça um nome de usuário para o usuário, como "UsuarioExemplo".
5. Selecione a opção "Acesso à AWS programático" para permitir que o usuário acesse a AWS via API.
6. Clique em "Avançar para permissões".
7. Adicione o usuário ao grupo criado anteriormente, selecionando o grupo no campo "Adicionar usuário a um grupo".
8. Clique em "Avançar para marcar".
9. Revise as informações do usuário e clique em "Criar usuário".
10. Anote as credenciais de acesso (ID da chave de acesso e chave de acesso secreta) geradas para o usuário.

Passo 4 - Atribuição de políticas de acesso ao usuário

1. Navegue até o serviço AWS IAM no Console de Gerenciamento da AWS.
2. Clique em "Usuários" no painel de navegação esquerdo.
3. Selecione o usuário que você criou anteriormente, como "UsuarioExemplo".
4. Clique na guia "Permissões".
5. Clique em "Adicionar permissões".
6. Selecione "Anexar política existente diretamente" para adicionar uma política de acesso existente.
7. Selecione as políticas de acesso desejadas para o usuário. Por exemplo, você pode selecionar a política "AmazonS3FullAccess" para conceder acesso completo aos serviços do Amazon S3.
8. Clique em "Avançar para revisar".
9. Revise as informações e clique em "Adicionar permissões".

Agora você criou um grupo no IAM com políticas de acesso adequadas e um usuário associado a esse grupo com as permissões necessárias. Esse usuário agora pode fazer login no Console de Gerenciamento da AWS e acessar os serviços e recursos conforme as políticas de acesso atribuídas. Certifique-se de seguir as práticas recomendadas de segurança, como aplicar autenticação de dois fatores (2FA) para garantir uma camada adicional de segurança para as contas do IAM.

Lembre-se de personalizar as configurações do IAM de acordo com as necessidades e requisitos de segurança da sua organização. O AWS IAM fornece um controle granular sobre o acesso aos recursos da AWS, permitindo que você defina políticas de permissão personalizadas e restrinja o acesso apenas aos usuários e recursos necessários. Isso ajuda a garantir a segurança da infraestrutura na nuvem e mitigar riscos de segurança.

9.2 Rastreamento de alterações de infraestrutura com AWS CloudTrail

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS CloudTrail relacionado ao domínio 3 - segurança de infraestrutura:

Passo 1: Configurar o CloudTrail

1. Acesse o Console de Gerenciamento da AWS em <https://console.aws.amazon.com>.
2. Navegue até o serviço AWS CloudTrail.
3. Clique em "Criar trilha".
4. Forneça um nome descritivo para a trilha, como "TrilhaExemplo".
5. Escolha a opção "Aplicar a todas as regiões" para registrar eventos em todas as regiões da AWS.
6. Selecione a opção "Sim" para habilitar o log de dados de gerenciamento.
7. Especifique o bucket do Amazon S3 onde os logs do CloudTrail serão armazenados.
8. Clique em "Avançar" para continuar.

Passo 2 - Configurar opções de log adicionais (opcional)

1. Na página "Opções de log adicionais", você pode selecionar opções adicionais de log, como log de dados de Insights, log de eventos de integridade ou log de eventos de dados confidenciais.

2. Selecione as opções desejadas com base nos requisitos de segurança e conformidade da sua organização.

3. Clique em "Avançar" para continuar.

Passo 3 - Configurar as permissões

1. Na página "Permissões", você pode especificar as permissões de acesso para a trilha do CloudTrail.

2. Selecione as permissões adequadas com base nos requisitos de acesso e segurança da sua organização.

3. Clique em "Avançar" para continuar.

Passo 4 - Revisar as configurações

1. Na página "Revisar", revise todas as configurações feitas anteriormente.

2. Verifique se todas as informações estão corretas antes de criar a trilha do CloudTrail.

3. Clique em "Criar trilha" para criar a trilha do CloudTrail.

Passo 5 - Analisar os logs do CloudTrail

1. Após a criação da trilha do CloudTrail, você pode navegar até o bucket do Amazon S3 especificado anteriormente para visualizar os logs gerados.

2. Abra o bucket do S3 e localize a pasta que corresponde ao nome da trilha do CloudTrail criada.

3. Dentro da pasta, você encontrará os logs organizados por data.

4. Clique em um arquivo de log para visualizá-lo e analisar as informações registradas.

Agora você configurou o CloudTrail para registrar eventos e atividades na sua infraestrutura da AWS. Isso permite que você tenha uma trilha de auditoria detalhada das ações realizadas em suas contas da AWS.

Você pode usar esses logs para análise de segurança, conformidade, investigação de incidentes e detecção de atividades maliciosas. Certifique-se de revisar regularmente os logs do CloudTrail para identificar quaisquer eventos suspeitos ou não autorizados.

9.3 Gestão de configuração de infraestrutura com AWS Config

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Config relacionado ao Domínio 3: Segurança de infraestrutura:

Passo 1 - Ativar o AWS Config

1. Acesse o Console de Gerenciamento da AWS em <https://console.aws.amazon.com>.
2. Navegue até o serviço AWS Config.
3. Clique em "Configurar AWS Config".
4. Selecione a opção "Habilitar o AWS Config".
5. Selecione a região em que deseja habilitar o AWS Config.
6. Clique em "Gravar configurações" para confirmar a ativação do AWS Config.

Passo 2 - Configurar as regras de configuração

1. Na página inicial do AWS Config, clique em "Regras de configuração" no painel de navegação esquerdo.
2. Clique em "Adicionar regra".
3. Selecione a opção "Regra gerenciada" para usar uma regra predefinida ou "Regra personalizada" para criar uma regra personalizada.
4. Escolha a regra desejada na lista ou crie sua própria regra personalizada.
5. Configure os parâmetros da regra de acordo com as necessidades de segurança da sua infraestrutura. Por exemplo, você pode configurar uma regra para verificar se as instâncias EC2 têm os patches de segurança mais recentes instalados.
6. Clique em "Salvar" para criar a regra de configuração.

Passo 3 - Analisar as configurações

1. Navegue até a página inicial do AWS Config e clique em "Avaliação de recursos" no painel de navegação esquerdo.
2. Selecione o tipo de recurso que deseja avaliar, como instâncias EC2.
3. Visualize os resultados da avaliação para verificar se os recursos estão em conformidade com as regras de configuração.
4. Caso algum recurso esteja em não conformidade, você pode tomar as medidas necessárias para corrigir a configuração e garantir a segurança da infraestrutura.

Passo 4 - Visualizar histórico de configuração

1. Navegue até a página inicial do AWS Config e clique em "Histórico de configuração" no painel de navegação esquerdo.
2. Selecione o recurso que deseja visualizar o histórico de configuração.
3. Analise as alterações feitas na configuração do recurso ao longo do tempo.
4. Identifique qualquer alteração não autorizada ou inconsistência na configuração.

Agora você configurou o AWS Config para monitorar e avaliar a conformidade da configuração dos recursos da sua infraestrutura da AWS. Isso permite que você identifique e corrija rapidamente quaisquer desvios de configuração que possam representar riscos de segurança. Além disso, você pode usar o histórico de configuração para rastrear e analisar as alterações feitas na configuração ao longo do tempo. Isso é essencial para garantir a segurança e a integridade da sua infraestrutura na nuvem.

9.4 Análise de eventos com GuardDuty

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço Amazon GuardDuty relacionado ao Domínio 3: Segurança de infraestrutura:

Passo 1 - Ativar o Amazon GuardDuty

1. Acesse o Console de Gerenciamento da AWS em <https://console.aws.amazon.com>.

2. Navegue até o serviço Amazon GuardDuty.
3. Clique em "Ativar o GuardDuty".
4. Selecione a região em que deseja ativar o GuardDuty.
5. Clique em "Continuar".

Passo 2 - Configurar o Amazon GuardDuty

1. Na página inicial do Amazon GuardDuty, clique em "Configuração" no painel de navegação esquerdo.
2. Selecione a opção "Habilitar para a conta da AWS" para ativar a proteção para a conta atual.
3. Escolha a opção "Habilitar CloudTrail" para usar os logs do CloudTrail como fonte de eventos de segurança.
4. Escolha a opção "Habilitar VPC Flow Logs" para usar os logs de fluxo da VPC como fonte de eventos de segurança.
5. Clique em "Salvar" para aplicar as configurações.

Passo 3 - Revisar as descobertas e alertas

1. Na página inicial do Amazon GuardDuty, clique em "Descobertas" no painel de navegação esquerdo.
2. Analise as descobertas e alertas de segurança apresentados pelo GuardDuty.
3. Clique em cada descoberta para obter mais detalhes e informações sobre a ameaça.
4. Tome as medidas apropriadas para investigar e responder às ameaças identificadas.

Passo 4 - Configurar notificações e integrações

1. Na página inicial do Amazon GuardDuty, clique em "Notificações" no painel de navegação esquerdo.
2. Configure as notificações para alertas de segurança, especificando os destinatários e os métodos de entrega desejados, como e-mail, SNS, Lambda, etc.

3. Se desejar, configure integrações com outros serviços da AWS para automatizar as ações de resposta às ameaças.

Passo 5 - Monitorar e gerenciar a segurança

1. Acompanhe regularmente as descobertas e alertas do Amazon GuardDuty para identificar e responder a possíveis ameaças.

2. Tome as medidas apropriadas para investigar, mitigar e remediar as ameaças identificadas pelo GuardDuty.

3. Monitore as configurações do GuardDuty e ajuste as configurações conforme necessário para otimizar a detecção de ameaças.

Agora você configurou o Amazon GuardDuty para monitorar e detectar ameaças de segurança na sua infraestrutura da AWS. O GuardDuty utiliza técnicas avançadas de análise e aprendizado de máquina para identificar atividades maliciosas ou não autorizadas. Certifique-se de revisar regularmente as descobertas e alertas do GuardDuty e tomar as medidas apropriadas para responder a possíveis ameaças. Isso ajudará a garantir a segurança contínua da sua infraestrutura na nuvem.

9.5 Proteção a ataques DDoS Shield

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Shield relacionado ao Domínio 3: Segurança de infraestrutura:

Passo 1 - Ativar o AWS Shield

1. Acesse o Console de Gerenciamento da AWS em <https://console.aws.amazon.com>.

2. Navegue até o serviço AWS Shield.

3. Clique em "Ativar o AWS Shield" na região desejada.

4. Selecione o tipo de proteção desejado: Standard ou Advanced.

5. Siga as instruções para concluir a ativação do AWS Shield.

Passo 2 - Configurar as configurações de proteção

1. Na página inicial do AWS Shield, clique em "Configurações" no painel de navegação esquerdo.

2. Configure as opções de proteção de acordo com as necessidades de segurança da sua infraestrutura.

3. Por exemplo, você pode configurar as configurações de mitigação automática, definir limites de tráfego ou ativar o AWS Shield Advanced para obter recursos adicionais de proteção.

4. Clique em "Salvar" para aplicar as configurações de proteção.

Passo 3 - Monitorar e responder a ataques

1. Na página inicial do AWS Shield, clique em "Eventos" no painel de navegação esquerdo.

2. Analise os eventos de ataque relatados pelo AWS Shield.

3. Avalie o impacto e a gravidade do ataque e tome as medidas apropriadas para mitigar e responder ao ataque.

4. Dependendo da gravidade do ataque, você pode usar as opções de mitigação automática do AWS Shield ou tomar medidas manuais adicionais, como bloquear IPs maliciosos ou ajustar as configurações de proteção.

Passo 4 - Configurar alarmes de proteção

1. Na página inicial do AWS Shield, clique em "Alarmes de proteção" no painel de navegação esquerdo.

2. Clique em "Criar alarme" para configurar alarmes de proteção personalizados com base em métricas específicas, como tráfego, ataques ou latência.

3. Defina as condições do alarme e as ações a serem executadas quando o alarme for acionado, como notificações por e-mail ou acionamento de fluxos de trabalho automatizados.

4. Clique em "Salvar" para criar o alarme de proteção.

Passo 5 - Revisar relatórios de proteção

1. Na página inicial do AWS Shield, clique em "Relatórios" no painel de navegação esquerdo.

2. Analise os relatórios de proteção fornecidos pelo AWS Shield, como o Relatório de Ataques e o Relatório de Tráfego.

3. Utilize esses relatórios para avaliar a eficácia das suas medidas de proteção e identificar áreas que precisam de melhorias adicionais.

Agora você configurou o AWS Shield para proteger sua infraestrutura contra ataques DDoS (Distributed Denial of Service) e outras ameaças. O AWS Shield fornece uma camada adicional de segurança para ajudar a mitigar e responder a ataques em tempo real. Certifique-se de revisar regularmente os eventos de ataque, configurar alarmes de proteção personalizados e ajustar as configurações de proteção de acordo com as necessidades da sua aplicação. Isso ajudará a garantir a segurança contínua da sua infraestrutura contra ameaças em constante evolução.

9.6 Provisionamento seguro de VPC

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço Amazon VPC (*Virtual Private Cloud*) relacionado ao domínio 3 - segurança de infraestrutura:

Passo 1 - Criação de uma Amazon VPC

1. Acesse o Console de Gerenciamento da AWS em <https://console.aws.amazon.com>.
2. Navegue até o serviço Amazon VPC.
3. Clique em "Criar VPC".
4. Forneça um nome descritivo para a VPC, como "VPCExemplo".
5. Escolha o bloco de endereço IP para a VPC.
6. Configure as opções de DNS e DHCP de acordo com as necessidades da sua infraestrutura.
7. Clique em "Criar VPC" para criar a VPC.

Passo 2 - Configuração de sub-redes

1. Após criar a VPC, clique em "Sub-redes" no painel de navegação esquerdo.
2. Clique em "Criar sub-rede".
3. Forneça um nome descritivo para a sub-rede, como "SubredeExemplo".
4. Escolha a VPC em que a sub-rede será criada.

5. Escolha o bloco de endereço IP para a sub-rede.
6. Escolha a zona de disponibilidade para a sub-rede.
7. Clique em "Criar" para criar a sub-rede.

Passo 3 - Configuração de grupos de segurança

1. Na página inicial do Amazon VPC, clique em "Grupos de segurança" no painel de navegação esquerdo.
2. Clique em "Criar grupo de segurança".
3. Forneça um nome descritivo para o grupo de segurança, como "GrupoSegurancaExemplo".
4. Escolha a VPC em que o grupo de segurança será associado.
5. Configure as regras de entrada e saída para o grupo de segurança com base nas necessidades de segurança da sua infraestrutura.
6. Clique em "Criar" para criar o grupo de segurança.

Passo 4 - Configuração de rotas e gateways

1. Na página inicial do Amazon VPC, clique em "Tabelas de roteamento" no painel de navegação esquerdo.
2. Clique em "Criar tabela de roteamento".
3. Forneça um nome descritivo para a tabela de roteamento, como "TabelaRoteamentoExemplo".
4. Escolha a VPC em que a tabela de roteamento será associada.
5. Configure as rotas e associe as sub-redes relevantes à tabela de roteamento.
6. Clique em "Criar" para criar a tabela de roteamento.

Passo 5 - Configuração de VPN ou Direct Connect (opcional)

1. Se necessário, configure uma conexão VPN ou Direct Connect para conectar sua VPC à sua infraestrutura local.
2. Navegue até o serviço AWS Site-to-Site VPN ou AWS Direct Connect para configurar a conexão adequada.

3. Siga as instruções fornecidas para configurar a conexão VPN ou Direct Connect.

Agora você configurou o Amazon VPC para criar uma rede virtual isolada para sua infraestrutura na nuvem. A VPC permite que você defina sua própria rede virtual, controle as configurações de rede, como sub-redes e grupos de segurança, e configure rotas de rede para direcionar o tráfego adequadamente.

Certifique-se de revisar e ajustar as configurações de segurança, como as regras de grupo de segurança, de acordo com as necessidades de proteção da sua infraestrutura. Isso ajudará a garantir a segurança e o isolamento adequados dos recursos da sua infraestrutura na nuvem.

9.7 Coleta e análise de dados com Security Hub

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Security Hub relacionado ao Domínio 3: Segurança de infraestrutura:

Passo 1 - Ativar o AWS Security Hub

1. Acesse o Console de Gerenciamento da AWS em <https://console.aws.amazon.com>.
2. Navegue até o serviço AWS Security Hub.
3. Clique em "Ativar o Security Hub".
4. Selecione a região em que deseja ativar o Security Hub.
5. Clique em "Ativar Security Hub".

Passo 2 - Configurar padrões de conformidade

1. Na página inicial do AWS Security Hub, clique em "Padrões de conformidade" no painel de navegação esquerdo.
2. Selecione os padrões de conformidade que deseja habilitar, como o CIS AWS Foundations Benchmark ou o PCI DSS.
3. Clique em "Ativar" para habilitar os padrões de conformidade selecionados.

Passo 3 - Configurar integração com outros serviços de segurança

1. Na página inicial do AWS Security Hub, clique em "Integrações" no painel de navegação esquerdo.
2. Ative a integração com outros serviços de segurança relevantes, como Amazon GuardDuty, AWS Inspector, AWS Macie, etc.
3. Configure as opções de integração de acordo com as necessidades da sua infraestrutura.
4. Clique em "Salvar alterações" para aplicar as configurações de integração.

Passo 4 - Monitorar e revisar as descobertas de segurança

1. Na página inicial do AWS Security Hub, clique em "Descobertas" no painel de navegação esquerdo.
2. Analise as descobertas de segurança apresentadas pelo Security Hub.
3. Clique em cada descoberta para obter mais detalhes e informações sobre a ameaça ou violação de segurança.
4. Tome as medidas apropriadas para investigar e responder às ameaças ou violações identificadas.

Passo 5 - Configurar notificações e automações

1. Na página inicial do AWS Security Hub, clique em "Notificações" no painel de navegação esquerdo.
2. Configure as notificações para alertas de segurança, especificando os destinatários e os métodos de entrega desejados, como e-mail, SNS, Lambda, etc.
3. Se desejar, configure automações para automatizar ações de resposta às ameaças, como a execução de fluxos de trabalho automatizados ou ações corretivas.
4. Clique em "Salvar alterações" para aplicar as configurações de notificação e automação

Agora você configurou o AWS Security Hub para monitorar e centralizar as descobertas de segurança da sua infraestrutura na nuvem. O Security Hub fornece uma visão consolidada do estado de segurança dos seus recursos e permite que você identifique, priorize e resolva problemas de segurança de forma mais eficiente.

Certifique-se de revisar regularmente as descobertas de segurança, configurar notificações e automatizar ações de resposta para garantir a segurança contínua da sua infraestrutura.

EMSE

REFERÊNCIAS

AWS. **AWS Architecture Icons**. 2023. Disponível em: <https://aws.amazon.com/pt/architecture/icons/>. Acesso em: 14 jul. 2023.

GOLDFARB, Dario et al. **AWS Certified Security Study Guide: Specialty (scs-c01) Exam**. Estados Unidos: Sybex, 2021.

PIERCE, Tracy et al. **AWS Certified Security Specialty Exam Guide: Exam scs-c01**. Estados Unidos: McGraw Hill, 2021.

EMANIP